

DDTA - Scheda di lettura compilata

SRC-0027 - Haley et al. (2008) - Security requirements satisfaction

Identita bibliografica

Campo	Valore
Titolo	Security Requirements Engineering: A Framework for Representation and Analysis
Autori	Haley, Laney, Moffett, Nuseibeh
Sede	IEEE TSE 34(1), 133-153
DOI	10.1109/TSE.2007.70754
PDF	21 pagine; testo e figure leggibili
SHA-256	811aac50e9707a6a89b4aa19fd1f702877fb8a8aa0770054117a6d870d5d0c43
Tipo	Framework con esempio e una applicazione industriale

Risultato centrale

Il metodo e pre-codice ma richiede un problem context strutturato, fenomeni condivisi e una descrizione del comportamento. L assurance e condizionale: dimostra che il sistema modellato puo soddisfare il requisito se contesto, comportamento e assunzioni sono validi.

Tre criteri di adeguatezza

Criterio	Obbligo
Definition	Definire il requisito come vincolo operativo
Assumptions	Rendere esplicite le trust assumptions
Satisfaction	Mostrare goal-to-requirement e system-to-requirement

Classificazione DDTA

documentation_plus_problem_context_behavior_model_required_or_created

SRC-0027 - Processo e artefatti

Quattro stadi

Stadio	Output
1	Functional goals, context e functional requirements
2	Assets, harms e security goals
3	Security requirements come vincoli sulle funzioni
4	Outer proof, inner arguments, rebuttals e trust assumptions

Catena di evidenza

business goals -> context -> functions -> assets/harms -> security goals -> security constraints -> outer argument -> inner argument -> rebuttal -> mitigation -> revised context

Dipendenze

Direzione	Significato
Top-down	Goal deriva requirement e lower artifact
Bottom-up	Feasibility o prova fallita forza revisione degli antenati
Iterative	Mitigazioni introducono nuovi domini, asset, fenomeni e requisiti

Security requirement

Vincolo prescrittivo su una specifica functional requirement, abbastanza preciso da essere consegnato a designer o architect. Non coincide con meccanismo, policy generica o scenario di attacco.

SRC-0027 - Satisfaction arguments

Outer argument

domain behavior premises |- security requirement

Condizione	Limite
Context correct	Non verificato automaticamente
Behavior complete	Possibili comportamenti omessi
No conflicting implementation	Richiede evidenza successiva
Logic adequate	Trade-off tra espressività e trattabilità

Inner argument

Elemento	Ruolo
Claim	Conclusione da sostenere
Grounds	Fatti o evidenza
Warrant	Connessione grounds-claim
Backing	Supporto del warrant
Qualifier	Forza o affidabilità
Rebuttal	Condizione che invalida il supporto
Trust assumption	Foglia non ulteriormente sostenuta

Diagnostica

Un argomento non costruibile può indicare contesto incompleto, requisito infeasible, premessa ingiustificata, trust assumption implicita o necessità di nuova mitigation.

SRC-0027 - Caso, limiti e implicazioni

CRISTAL UK / NATS

Passaggio	Risultato
Input	ADS-B come possibile primary position source
Prima iterazione	8 threat descriptions, 2 security goals, 2 constraints
Argument review	12 rebuttals iniziali
Mitigation	Multilateration
Nuovi rebuttal	Identity, virtual transmitters, clock synchronization

Limiti empirici

Aspetto	Valutazione
Evidence	Una applicazione industriale e esempi
Comparison	Nessun baseline controllato
Completeness	Non dimostrata
Human effort	Non misurato
Tool support	Ritenuto insufficiente
Rebuttal recipe	Non disponibile
Stopping	Non formalizzato

Confronto

Fonte	Centro	Assurance
SRC-0003	Scenario di misuse	Review e trace links
SRC-0004	Anti-goal	Formal regression e local proof
SRC-0027	Constraint e assumption	Outer proof + inner argument

Implicazioni DDTA

Separare Base Analysis, security constraint e assurance claim; preservare premise, proof status, rebuttal, trust assumption, mitigation alternative, cover/replace ancestry e source provenance; rieseguire solo i frammenti impattati dai cambiamenti.